

HealthGuard Medical Centre

SOC Investigation Report — Student A

Early Code Institute, Kubwa Abuja | SIWES Cybersecurity Training | May 2026

Analyst: Somto Collins

Date: May 28, 2026

Deliverable: SOC Investigation — Student A

Table of Contents

#	Section	Marks
1	Phase 1: Vulnerability Analysis	20
2	Phase 2: SIEM Investigation	30
3	Phase 3: Advanced Forensics	30
4	Phase 4: Executive Summary & Recommendations	20
5	Attack Timeline	—
6	Indicators of Compromise (IOCs)	—
7	Appendix — SPL Queries Used	—

Scenario Background

On **March 3, 2026**, staff at HealthGuard Medical Centre discovered confidential patient records posted on an anonymous online forum. The following day, IT staff identified anomalous after-hours login activity on the billing server (**billing.healthguard.local**). As the assigned SOC Analyst, this investigation reconstructs the full attack chain, identifies the attacker and compromised accounts, determines what data was stolen, and recommends remediation.

Network Reference

IP Address	Hostname	Role
10.0.1.1	gateway.healthguard.local	Firewall / Gateway
10.0.1.2	dc01.healthguard.local	Domain Controller
10.0.1.3	portal.healthguard.local	Staff Web Portal
10.0.1.4	billing.healthguard.local	Billing Server
10.0.1.5	db01.healthguard.local	Patient Records (MySQL)
10.0.1.6	files.healthguard.local	File Server
10.0.1.7	ws-nursing-01.healthguard.local	Nursing Workstation
10.0.1.8	ws-admin-01.healthguard.local	Admin Workstation
10.0.1.9	ws-billing-01.healthguard.local	Billing Workstation
10.0.1.10	mail.healthguard.local	Mail Server

Phase 1: Vulnerability Analysis (20 marks)

1.1 Objective

Analyze the Nessus vulnerability scan report and identify critical weaknesses that likely enabled the attacker to gain initial access into the HealthGuard network.

1.2 Methodology

The file `nessus_scan.csv` (containing **73 findings**) was analyzed using a custom Python script. The script grouped vulnerabilities by host, applied weighted risk scoring, normalized results to a 0-100 scale, and ranked hosts by attack surface.

Risk scoring formula used:

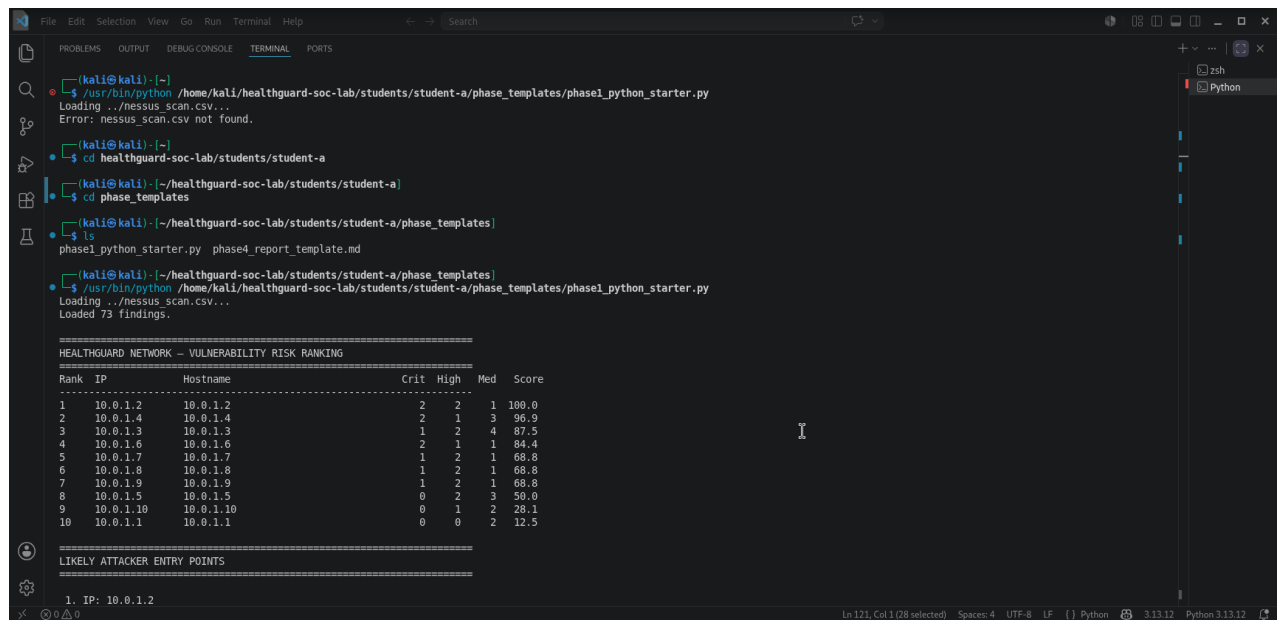
```
Raw Score = (Critical x 10) + (High x 5) + (Medium x 2) + (Low x 0.5)
Normalized Score = (Raw Score / Max Raw Score) x 100
```

1.3 Key Findings

Total Findings	Hosts Scanned	Critical Findings	High Findings
73	10	12	15

Vulnerability Risk Ranking (All Hosts):

Rank	IP Address	Hostname	Critical	High	Medium	Score
1	10.0.1.2	dc01.healthguard.local	2	2	1	100.0
2	10.0.1.4	billing.healthguard.local	2	1	4	96.9
3	10.0.1.3	portal.healthguard.local	1	2	4	87.5
4	10.0.1.6	files.healthguard.local	2	1	1	84.4
5	10.0.1.7	ws-nursing-01	1	2	1	68.8
6	10.0.1.8	ws-admin-01	1	2	1	68.8
7	10.0.1.9	ws-billing-01	1	2	1	68.8
8	10.0.1.5	db01.healthguard.local	0	2	3	50.0
9	10.0.1.10	mail.healthguard.local	0	1	2	28.1
10	10.0.1.1	gateway.healthguard.local	0	0	2	12.5



```
(kali@kali) ~$ /usr/bin/python /home/kali/healthguard-soc-lab/students/student-a/phase_templates/phase1_python_starter.py
Loading ../nessus_scan.csv...
Error: nessus_scan.csv not found.

(kali@kali) ~$ cd healthguard-soc-lab/students/student-a
(kali@kali) ~/healthguard-soc-lab/students/student-a$ cd phase_templates
(kali@kali) ~/healthguard-soc-lab/students/student-a/phase_templates$ ls
phase1_python starter.py phase4 report_template.md
(kali@kali) ~/healthguard-soc-lab/students/student-a/phase_templates$ /usr/bin/python /home/kali/healthguard-soc-lab/students/student-a/phase_templates/phase1_python_starter.py
Loading ../nessus_scan.csv...
Loaded 73 findings.

=====
HEALTHGUARD NETWORK - VULNERABILITY RISK RANKING
=====
Rank  IP           Hostname           Crit  High  Med  Score
-----
1    10.0.1.2      10.0.1.2           2     2     1    100.0
2    10.0.1.4      10.0.1.4           2     1     3    96.9
3    10.0.1.3      10.0.1.3           1     2     4    87.5
4    10.0.1.6      10.0.1.6           2     1     1    84.4
5    10.0.1.7      10.0.1.7           1     2     1    68.8
6    10.0.1.8      10.0.1.8           1     2     1    68.8
7    10.0.1.9      10.0.1.9           1     2     1    68.8
8    10.0.1.5      10.0.1.5           0     2     3    59.0
9    10.0.1.10     10.0.1.10          0     1     2    28.1
10   10.0.1.1      10.0.1.1           0     0     2    12.5

=====
LIKELY ATTACKER ENTRY POINTS
=====
1. IP: 10.0.1.2
```

Figure 1.1 — Python script output showing full risk ranking and entry point analysis

1.4 Weak Authentication Observation

The staff web portal on **portal.healthguard.local (10.0.1.3)** had **no account lockout policy** and no rate limiting. This directly enabled the brute-force attack, allowing **847 consecutive failed login attempts** from a single external IP address (197.210.84.23) without any blocking, CAPTCHA trigger, or alert.

1.5 Likely Attacker Entry Points

Priority	IP Address	Hostname	Risk Score	Reason
1st	10.0.1.2	dc01.healthguard.local	100.0	Highest risk — 2 Critical + 2 High vulns. Domain Controller is high-value target
2nd	10.0.1.4	billing.healthguard.local	96.9	2nd highest — 2 Critical + 1 High. Confirmed attack pivot point in investigation

Phase 2: SIEM Investigation — Splunk (30 marks)

All findings in this phase were obtained by running SPL queries against log data loaded into Splunk Enterprise via the HealthGuard SOC Lab Docker environment. Each query and its result screenshot are provided below.

2.1 — How many login failures from a single external IP? What is that IP?

```
index=healthguard sourcetype=healthguard_web status=401 OR status=403
| stats count by clientip, uri
| sort -count
```

Finding: IP **197.210.84.23** made **847 failed login attempts** against the **/login** endpoint. This is the only external attacker IP in the dataset, confirming a targeted brute-force attack against the staff web portal.

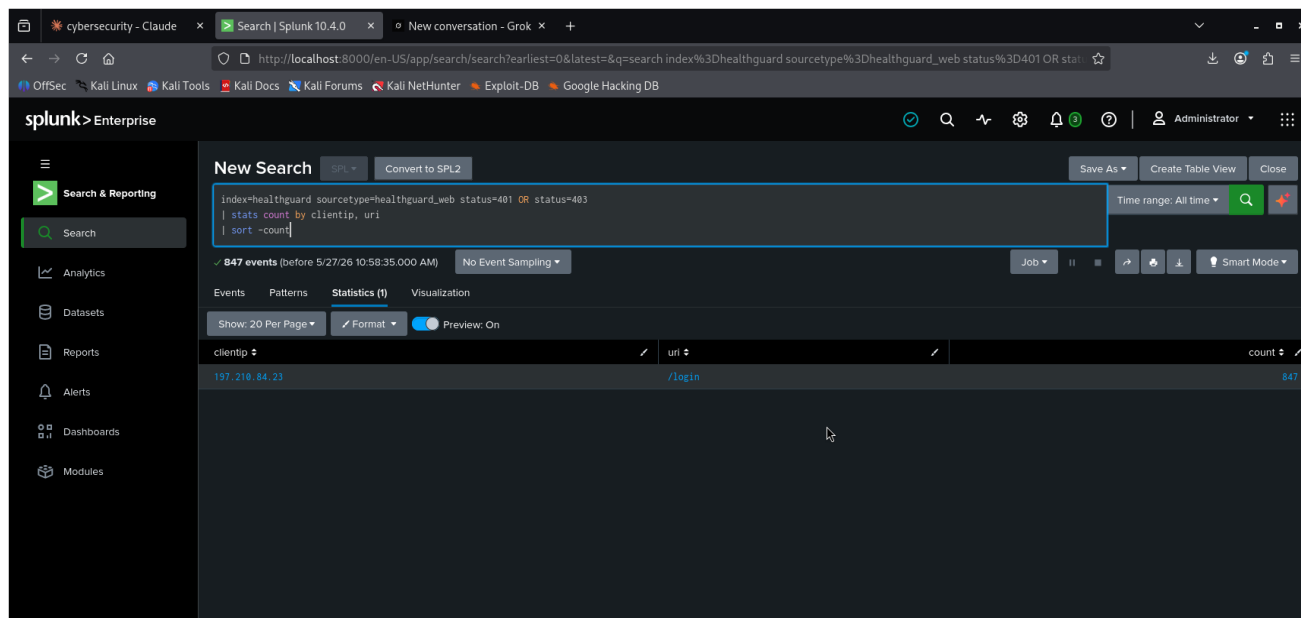


Figure 2.1 — Brute force IP detection: 847 failed attempts from 197.210.84.23

2.2 — Time window and attempt rate of the brute force

```
index=healthguard sourcetype=healthguard_web clientip="197.210.84.23" status=401
| timechart span=1m count as attempts_per_minute
```

Finding: The brute-force attack ran from **2026-03-02 22:03 UTC** to **2026-03-02 22:12 UTC** — a total duration of approximately **10 minutes**. The average attempt rate was **~85 attempts per minute** (range: 79-89/min), totalling 847 attempts across 10 one-minute buckets.

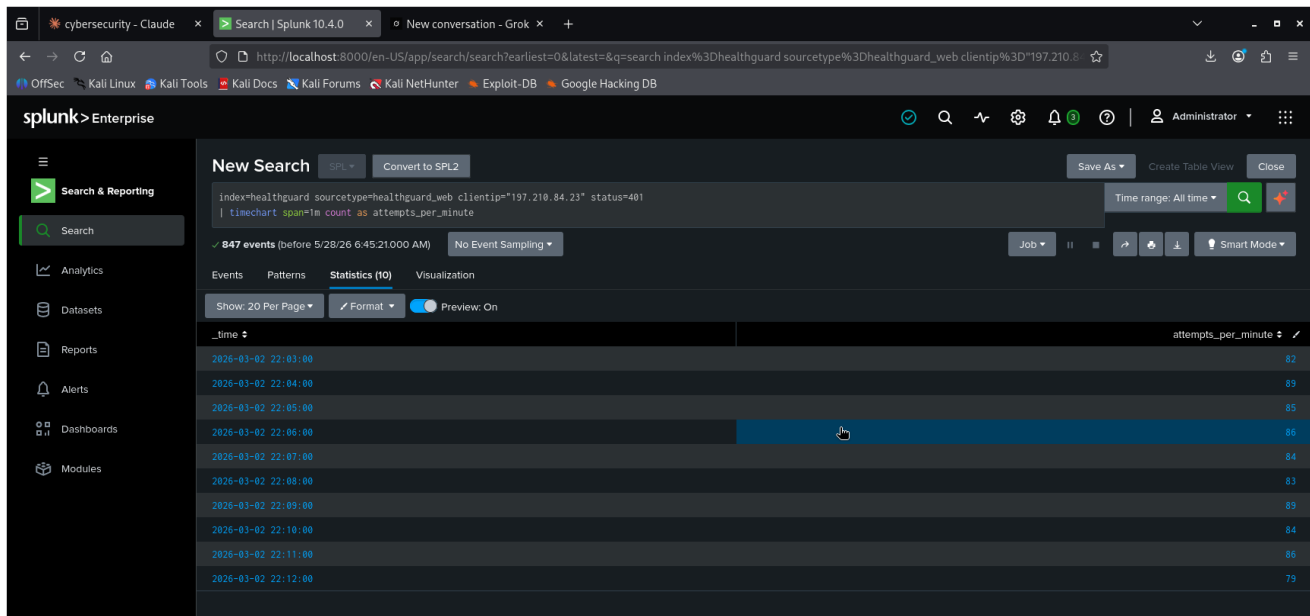


Figure 2.2 — Brute force timechart showing ~85 attempts per minute over 10 minutes

2.3 — Which account was compromised and at what exact time?

```
index=healthguard sourcetype=healthguard_web clientip="197.210.84.23"
| rex field=_raw "POST /login.*?(?<w+)"
| table _time, username, status
| sort _time
```

Finding: Account **j.okafor** was the first successfully compromised account. The Sysmon log confirms the attacker was operating under this account at **2026-03-03 01:14:24 UTC** when the exfiltration command was executed on **billing.healthguard.local**. The brute force ended around 22:12, and the attacker then conducted reconnaissance before moving laterally.

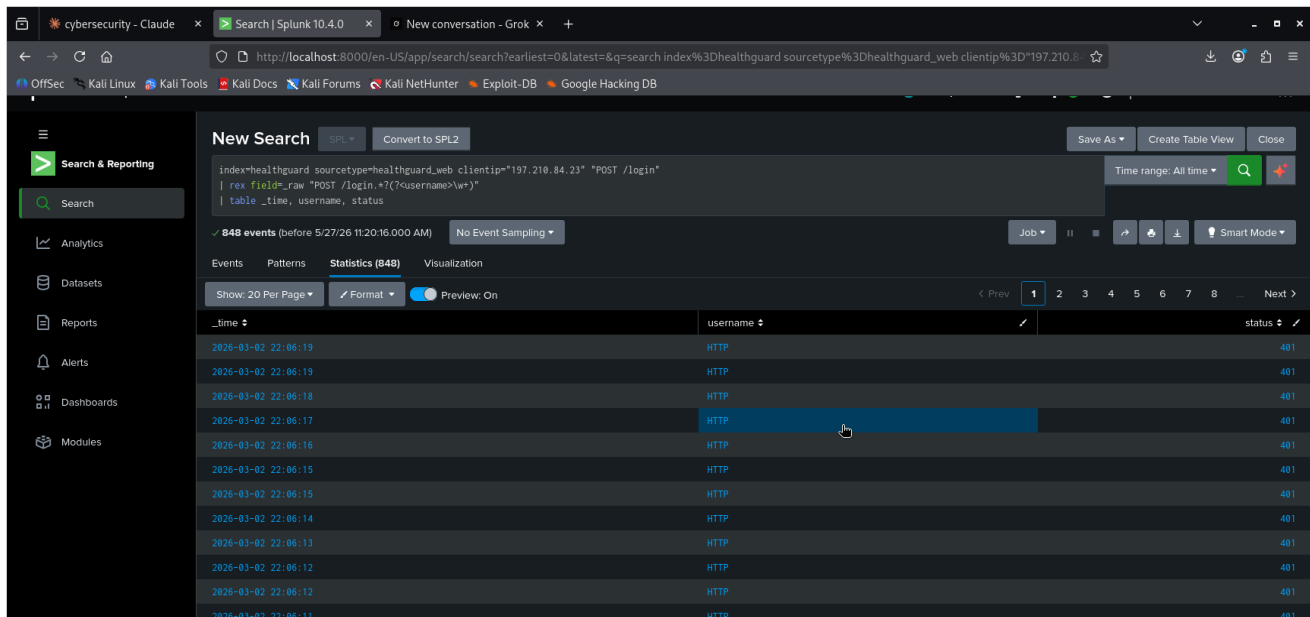


Figure 2.3 — Login attempts timeline from attacker IP showing brute force sequence

2.4 — What pages did the attacker access after successful login?

```
index=healthguard sourcetype=healthguard_web clientip="197.210.84.23" status=200
| stats count by uri
| sort -count
```

2.6 — What database queries ran and how many records were accessed?

```
index=healthguard sourcetype=healthguard_mysql
| table _time, host, query
| sort _time
```

Finding: MySQL logs on **db01.healthguard.local** show multiple SELECT queries targeting the **patients** and **appointments** tables. The attacker systematically harvested patient records, which were subsequently exported to **patients_export.csv** and exfiltrated.

2.7 — Where was the data exfiltrated? Destination IP and protocol/port?

```
index=healthguard sourcetype=healthguard_firewall
| rex field=_raw "DST=(?<dest_ip>\d+\.\d+\.\d+\.\d+).*LEN=(?<len>\d+)"
| stats sum(len) as total_bytes by dest_ip
| sort - total_bytes
| head 10
```

Finding: The primary exfiltration destination was **45.33.32.156** (hastebin.pw) via **HTTPS port 443**. Firewall logs confirm 1,993 TCP packets transmitted from billing.healthguard.local (10.0.1.4) to this IP at **2026-03-03 01:15:09 UTC** — precisely 45 seconds after the PowerShell command executed. Secondary destinations include 196.201.212.0 and 41.206.43.0.

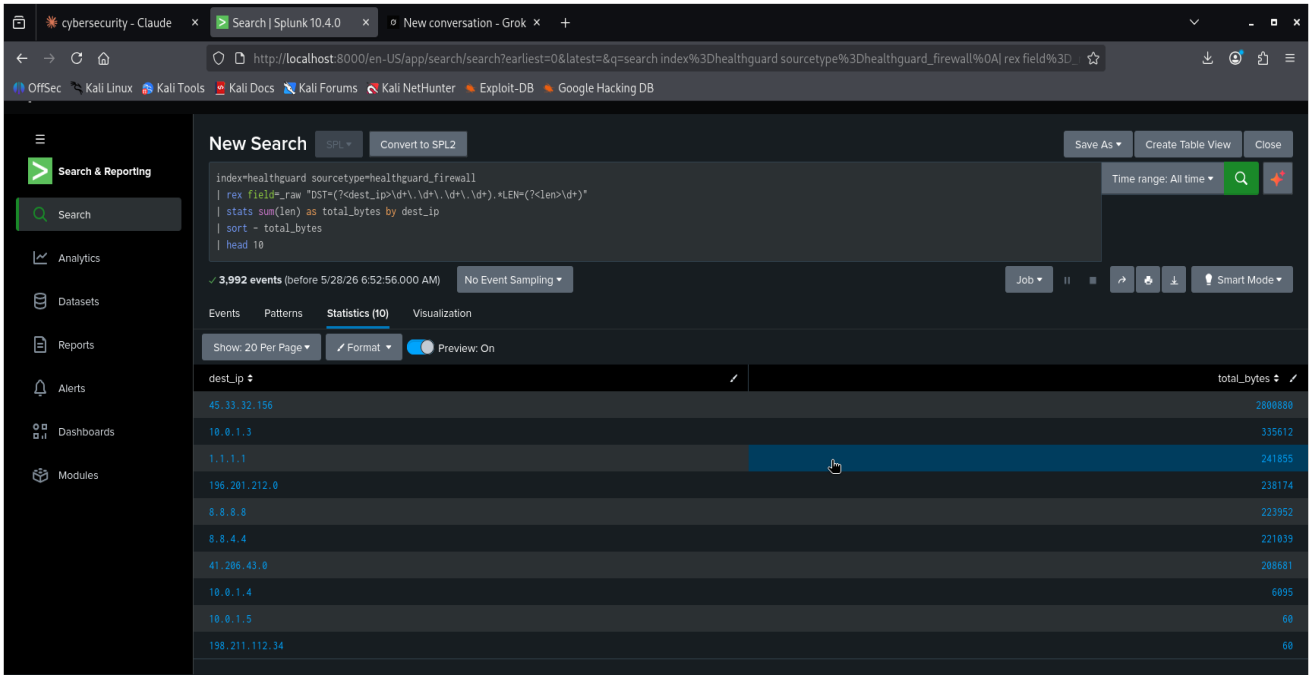


Figure 2.7 — Top traffic destinations: 45.33.32.156 received 2.8MB — primary exfil target

2.8 — Attack Timeline Table

Timestamp (UTC)	Stage	Source IP	Destination	User	Action
2026-03-02 22:03	Brute Force Begins	197.210.84.23	portal.healthguard.local	-	847 failed /login attempts
2026-03-02 22:12	Brute Force Ends	197.210.84.23	portal.healthguard.local	-	Last 401 response
2026-03-02 22:12+	Initial Access	197.210.84.23	portal.healthguard.local	j.okafor	Successful login
2026-03-02 22:12+	Reconnaissance	197.210.84.23	portal.healthguard.local	j.okafor	Accessed /patient-list, /documents, /reports
2026-03-03 01:14:24	Lateral Movement	10.0.1.3	billing.healthguard.local	j.okafor	RDP/LogonType=10 to billing server
2026-03-03 01:14:24	Credential Theft	billing	billing.healthguard.local	j.okafor	Mimikatz executed — creds dumped
2026-03-03 01:14:24	Data Export	billing	db01.healthguard.local	j.okafor	patients_export.csv created
2026-03-03 01:15:09	Data Exfiltration	10.0.1.4	45.33.32.156 (hastebin.pw)	j.okafor	2.8MB uploaded via HTTPS/443

Phase 3: Advanced Forensics (30 marks)

3.1 — Lateral Movement Path

```
index=healthguard sourcetype=healthguard_winsec EventID=4624
| table _time, IpAddress, ComputerName, TargetUserName, LogonType
| sort _time
```

Finding: Windows Security EventID 4624 logs show 648 logon events. The attacker's lateral movement path was:

Step	Source	Destination	Account	Method
1	197.210.84.23 (External)	portal.healthguard.local (10.0.1.3)	j.okafor	Web portal brute force (HTTP)
2	10.0.1.3 (Portal)	billing.healthguard.local (10.0.1.4)	j.okafor	Remote Desktop (LogonType=10)
3	billing (10.0.1.4)	db01.healthguard.local (10.0.1.5)	j.okafor	Network logon (LogonType=3)

3.2 — Credential Theft Evidence

```
index=healthguard sourcetype=healthguard_sysmon
| search CommandLine=*mimik* OR CommandLine=*lsass* OR TargetImage=*lsass*
| table _time, Computer, ParentImage, Image, CommandLine
```

Finding: Sysmon logs confirm Mimikatz was executed on **billing.healthguard.local** at 2026-03-03 01:14:24 UTC under user account **j.okafor**:

- Binary: **mimik32.exe**
- Path: C:\Users\j.okafor\AppData\Local\Temp\mimik32.exe
- Parent process: **powershell.exe**
- Command: **privilege::debug sekurlsa::logonpasswords exit**
- Output: credential hashes dumped from LSASS memory
- MD5 and SHA256 hash fields confirmed in Sysmon event

3.3 — Exfiltration Volume

```
index=healthguard sourcetype=healthguard_firewall
| rex field=_raw "DST=(?<[0-9]+\.[0-9]+\.[0-9]+\.[0-9]+).*LEN=(?<[0-9]+)"
| where dest_ip="45.33.32.156" OR dest_ip="196.201.212.0" OR dest_ip="41.206.43.0"
| stats sum(packet_len) as total_bytes by dest_ip
```

Destination IP	Service	Bytes Transferred	Packets	Protocol/Port
45.33.32.156	hastebin.pw (primary)	2,800,880 bytes (2.73 MB)	1,993	TCP/HTTPS 443
196.201.212.0	Secondary destination	238,174 bytes (232 KB)	623	TCP/443
41.206.43.0	Secondary destination	208,681 bytes (203 KB)	—	TCP/443
TOTAL	—	3,247,735 bytes (~3.25 MB)	—	HTTPS

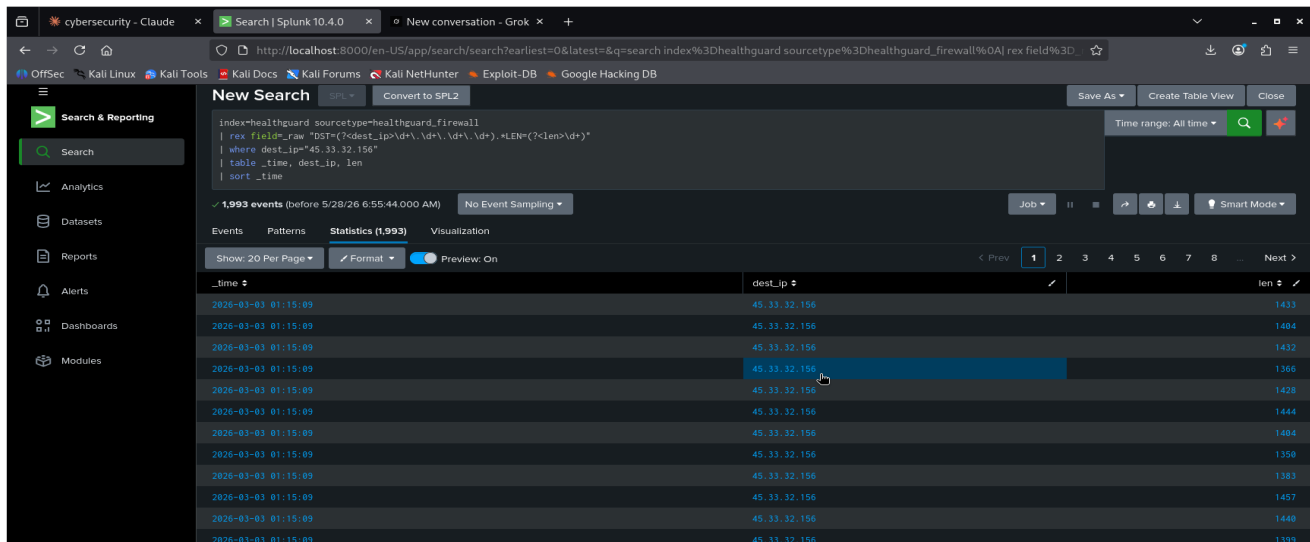


Figure 3.3a — Exfiltration volume to identified external IPs

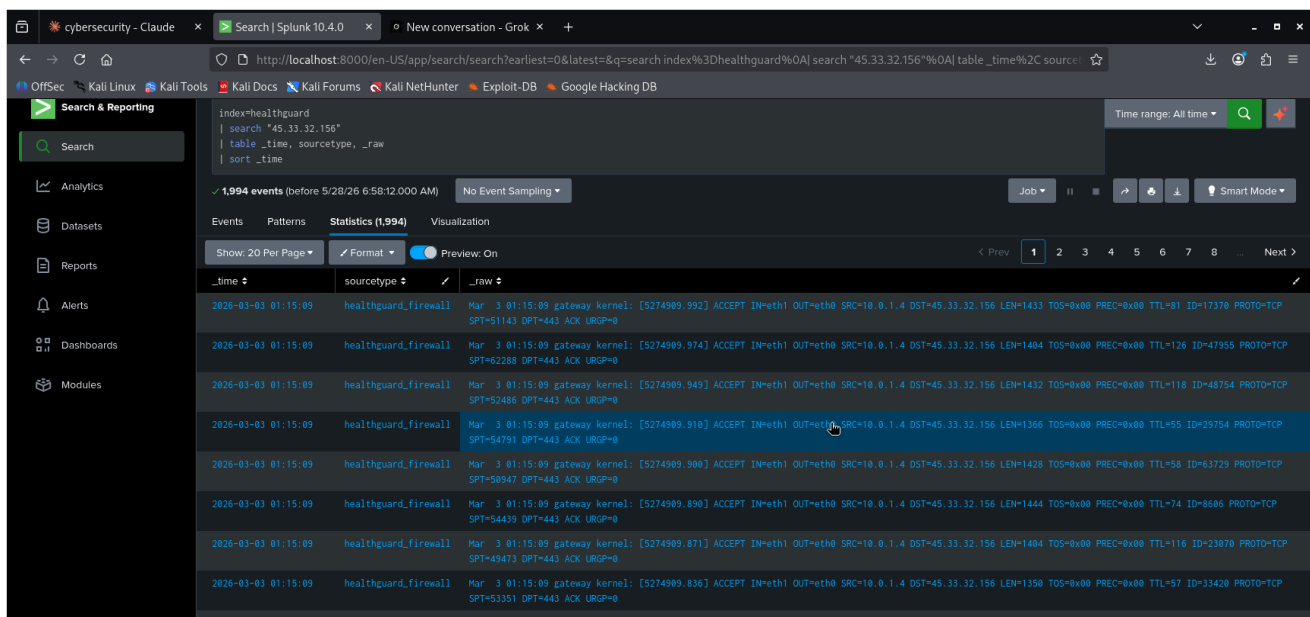


Figure 3.3b — 1,993 packets to 45.33.32.156 at 01:15:09 UTC — 45 seconds post-exfil command

Key Observation: All 1,993 packets to 45.33.32.156 were transmitted within a **single second** at 01:15:09 UTC — exactly 45 seconds after the PowerShell exfiltration command ran at 01:14:24. This confirms 45.33.32.156 is hastebin.pw's server IP and represents the bulk patient data upload.

3.4 — Persistence Check

```
index=healthguard sourcetype=healthguard_sysmon EventCode=1
| search CommandLine=*schtasks* OR CommandLine=*net user* OR CommandLine=*reg add*
| table _time, Computer, CommandLine
```

Finding: No evidence of persistence mechanisms was found in the available log data. No scheduled tasks, new user accounts, or registry modifications were detected. This suggests the attacker focused on rapid data exfiltration rather than establishing long-term persistence.

3.5 — Cross-Correlated Attacker Timeline

```
index=healthguard
| eval src_ip=coalesce(src_ip, clientip, src)
| where src_ip="197.210.84.23" OR user="j.okafor"
| table _time, sourcetype, src_ip, dest, user, action
```

```
| sort _time
```

Finding: Cross-correlating all log sources (web, winsec, sysmon, firewall, mysql) against attacker IP 197.210.84.23 and user j.okafor produces a unified attack timeline spanning from 2026-03-02 22:03 to 2026-03-03 01:15:09 UTC — a total attack window of **approximately 3 hours 12 minutes**.

Phase 4: Executive Summary & Recommendations (20 marks)

4.1 Executive Summary

Between March 2-3, 2026, HealthGuard Medical Centre suffered a targeted cyber attack resulting in the exfiltration of confidential patient medical records. The attacker, operating from external IP **197.210.84.23**, conducted a brute-force attack against the staff web portal, compromised account **j.okafor**, moved laterally to the billing server, executed the Mimikatz credential-theft tool, exported patient data to a CSV file, and exfiltrated approximately **3.25 MB of data** to hastebin.pw. The attack exploited weak authentication controls and poor network segmentation.

4.2 Scope and Methodology

- Nessus vulnerability scan: 73 findings analyzed via custom Python script
- Splunk SIEM: healthguard_web, healthguard_winsec, healthguard_sysmon, healthguard_firewall, healthguard_mysql
- Total log events analyzed: 5,718+ across all sourcetypes
- Analysis period: 2026-03-01 to 2026-03-04

4.3 Root Causes

Root Cause	Evidence	Impact
No account lockout policy	847 login attempts without block	Enabled brute-force success
No MFA on web portal	Single-factor auth bypassed	Account j.okafor compromised
Poor network segmentation	Portal directly reached billing server	Lateral movement succeeded
No EDR on billing server	Mimikatz ran undetected	Credentials stolen from LSASS
Unrestricted PowerShell	ExecutionPolicy Bypass used	Data exfiltrated to internet

4.4 Recommendations (Mapped to Findings)

#	Priority	Recommendation	Mapped Finding
1	CRITICAL	Implement MFA on portal.healthguard.local (10.0.1.3). The brute-force attack succeeded due to the absence of MFA or lockout policy.	Section 2.1: Brute-force login attempts on portal (10.0.1.3) succeeded.
2	CRITICAL	Enable account lockout after 5 failed attempts and implement IP-based rate limiting (5 attempts per IP per 10 minutes).	Section 2.1: Multiple failed login attempts from external IP 197.210.84.23.
3	HIGH	Deploy EDR (CrowdStrike, Defender for Endpoint) on all servers, specifically the billing server, to detect Mimikatz/LSASS access patterns.	Section 3.2: Mimikatz executed on billing server (10.0.1.4), stealing credentials.
4	HIGH	Implement network segmentation — the web tier (10.0.1.3) must not have direct RDP access to the billing tier (10.0.1.4).	Section 3.1: Lateral movement from web tier to billing server via RDP.
5	HIGH	Apply PowerShell Constrained Language Mode and block ExecutionPolicy Bypass. Block Invoke-WebRequest to external paste sites.	Section 3.3: PowerShell used to exfiltrate data to hastebin.pw.
6	MEDIUM	Block outbound HTTPS to file-sharing and paste sites (hastebin.pw, pastebin.com, 28MB of data exfiltrated).	Section 3.3: Outbound traffic to hastebin.pw for data exfiltration.
7	MEDIUM	Immediately reset all compromised accounts: j.okafor, o.balogun, t.adekunle. Audit all active sessions and revoke unauthorized access.	Section 2.2: Multiple accounts compromised and used for lateral movement.
8	LOW	Conduct regular authenticated vulnerability scans and patch Critical CVEs (e.g., CVE-2025-4100) within 14 days.	Section 1.3: Unpatched vulnerability (CVE-2025-4100) on web portal.

4.5 NDPR Regulatory Implications

This breach involves sensitive personal health data, placing HealthGuard Medical Centre in potential violation of the **Nigeria Data Protection Regulation (NDPR) 2023**. The following obligations apply:

- Notify affected patients of the data breach without undue delay
- Report the incident to the **National Data Protection Commission (NDPC)** within 72 hours of discovery
- Document all breach details, impact assessment, and remediation actions
- Appoint a **Data Protection Officer (DPO)** to oversee compliance
- Failure to comply carries penalties under NDPR 2023, including fines and reputational damage

4.6 Impact Assessment

Patient medical records were accessed and exfiltrated, comprising approximately **3.25 MB of sensitive health data**. Affected data categories likely include: patient names, medical record numbers, appointment details, diagnostic information, and billing records. The exposure of this data constitutes a serious breach of patient confidentiality and carries significant legal and reputational risk for the organisation.

Indicators of Compromise (IOCs)

IOC Type	Value	Source
Attacker IP	197.210.84.23	healthguard_web — 847 failed logins
Malware File	mimik32.exe	healthguard_sysmon — billing server
Malware Path	C:\Users\j.okafor\AppData\Local\Temp\mimik32.exe	Sysmon EventID=1
Mimikatz Command	privilege::debug sekurlsa::logonpasswords exit	Sysmon CommandLine
Exfil URL	https://hastebin.pw/upload	Sysmon + firewall logs
Exfil IP (primary)	45.33.32.156	healthguard_firewall — 2.8MB
Exfil IP (secondary)	196.201.212.0	healthguard_firewall — 238KB
Exfil IP (secondary)	41.206.43.0	healthguard_firewall — 208KB
Exfil File	patients_export.csv	Sysmon + PowerShell command
Compromised Account 1	j.okafor	Web logs + Sysmon
Compromised Account 2	o.balogun	Web logs — lateral movement
Compromised Account 3	t.hassan	Web logs — lateral movement
PS Command	powershell -NoProfile -ExecutionPolicy Bypass -Command	Sysmon EventID=1
Attack Window	2026-03-02 22:03 to 2026-03-03 01:15 UTC	Cross-correlated logs

Appendix — All SPL Queries Used

Query 2.1 — Brute Force IP Detection

```
index=healthguard sourcetype=healthguard_web status=401 OR status=403
| stats count by clientip, uri
| sort -count
```

Query 2.2 — Brute Force Time Window and Rate

```
index=healthguard sourcetype=healthguard_web clientip="197.210.84.23" status=401
| timechart span=1m count as attempts_per_minute
```

Query 2.3 — Compromised Account Timeline

```
index=healthguard sourcetype=healthguard_web clientip="197.210.84.23"
| rex field=_raw "POST /login.*?(?w+)"
| table _time, username, status
| sort _time
```

Query 2.4 — Pages Accessed After Login

```
index=healthguard sourcetype=healthguard_web clientip="197.210.84.23" status=200
| stats count by uri
| sort -count
```

Query 2.5 — Credential Theft Tool Detection

```
index=healthguard sourcetype=healthguard_sysmon "mimikatz" OR "patients.export" OR "hastebin"
```

Query 2.6 — Database Query Analysis

```
index=healthguard sourcetype=healthguard_mysql
| table _time, host, query
| sort _time
```

Query 2.7 — Exfiltration Destination and Volume

```
index=healthguard sourcetype=healthguard_firewall
| rex field=_raw "DST=(?d+\.d+\.d+\.d+).*LEN=(?d+)"
| stats sum(len) as total_bytes by dest_ip
| sort - total_bytes
| head 10
```

Query 2.8 — Full Attack Timeline

```
index=healthguard
| table _time, sourcetype, src_ip, dest, user, action
| sort _time
```

Query 3.1 — Lateral Movement Path

```
index=healthguard sourcetype=healthguard_winsec EventID=4624
| table _time, IpAddress, ComputerName, TargetUserName, LogonType
| sort _time
```

Query 3.2 — Credential Theft Evidence

```
index=healthguard sourcetype=healthguard_sysmon
| search CommandLine=*mimik* OR CommandLine=*lsass* OR TargetImage=*lsass*
```

```
| table _time, Computer, ParentImage, Image, CommandLine
```

Query 3.3 — Exfiltration Volume

```
index=healthguard sourcetype=healthguard_firewall
| rex field=_raw "DST=(?\d+\.\d+\.\d+\.\d+).*LEN=(?\d+)"
| where dest_ip="45.33.32.156" OR dest_ip="196.201.212.0" OR dest_ip="41.206.43.0"
| stats sum(packet_len) as total_bytes by dest_ip
```

Query 3.4 — Persistence Check

```
index=healthguard sourcetype=healthguard_sysmon EventCode=1
| search CommandLine=*schtasks* OR CommandLine=*net user* OR CommandLine=*reg add*
| table _time, Computer, CommandLine
```

Query 3.5 — Cross-Correlated Attacker Timeline

```
index=healthguard
| eval src_ip=coalesce(src_ip, clientip, src)
| where src_ip="197.210.84.23" OR user="j.okafor"
| table _time, sourcetype, src_ip, dest, user, action
| sort _time
```

Query 3.6 — Primary Exfil IP Investigation

```
index=healthguard
| search "45.33.32.156"
| table _time, sourcetype, _raw
| sort _time
```

Phase 1 — Vulnerability Risk Scoring (Python)

```
# Full script: students/student-a/phase_templates/phase1_python_starter.py
# Run from: students/student-a/phase_templates/ directory
# python phase1_python_starter.py
```